

一、 填空题

课本

1. (P6) 大数据安全包含 **大数据服务中的安全问题** 和 **大数据技术在安全领域的应用** 两重含义。
2. (P6) 大数据技术在安全领域的应用，主要包括以下两个方面的内容：**利用大数据技术解决安全问题** 和 **攻击者基于大数据技术开发新的攻击技术**。
3. (P9) 2021年，我国颁布实施了两部数据安全方面的基础性法律：《**中华人民共和国个人信息保护法**》和《**中华人民共和国数据安全法**》。
4. (P34) 密码学的攻击模型可以分为 **黑盒攻击**、**灰盒攻击** 和 **白盒攻击**。
5. (P37) 一次一密系统是否满足 NM（不可塑性，Non-malleability）的安全目标？**不满足**。
6. (P49) TLS协议可分为 **TLS握手协议**（负责密码组件的协商以及安全信道的建立）和 **TLS记录协议**（在已建立的安全信道中传输秘密信息）。
7. (P96) 在 FIDO UAF 协议中，用户通过位于设备本地的认证器完成 **身份识别** 并产生公私钥对，认证器使用私钥签名，服务端使用 **公钥** 进行验证，完成身份认证。
8. (P107) 在 Kerberos 协议中有两种票据，**票据许可票据** 用于用户访问票据授权服务器，**服务票据** 用于用户访问应用服务器。
9. (P110) 开放认证授权 (OAuth) 协议的四种模式：**授权码模式**、**简化模式**、**密码模式** 和 **客户端模式**。
10. (P131) 容器技术的三个核心概念：**镜像**、**容器** 和 **仓库**。
11. (P136) 常见的容器安全问题有 **容器逃逸问题**、**镜像安全问题**、**集群入侵**。
12. (P136) 产生容器逃逸的主要原因有两类：**软件漏洞** 和 **错误的配置**。
13. (P174) 安全多方计算模型可以分为 **半诚实模型** 和 **恶意模型**。
14. (P174) 安全多方计算模型中的参与者可以分为三类：**诚实参与者**、**半诚实参与者** 和 **恶意参与者**。
15. (P175) 在无限计算能力的攻击者模型下的安全的多方计算协议为 **基于信息论安全** 的多方计算协议；在有限计算能力的攻击者模型下的安全的多方计算协议为 **基于密码学安全** 的多方计算协议。
16. (P233) 发布-遗忘模型中数据匿名化的主要步骤包括：识别身份信息、**抑制**、**泛化** 和 **聚合**。
17. (P241) 差分隐私的通用随机算法有 **拉普拉斯机制**、**指数机制** 和 **高斯机制**。
18. (P310) 匿名属性包括 **不可辨识性** 和 **不可联系性**。

PPT、课后习题

19. (PPT-CH2-38) 密钥封装机制 (Key Encapsulation Mechanism, KEM) 是指 **用非对称加密算法加密对称密钥**；数据封装机制 (Data Encapsulation Mechanism, DEM) 是指 **用对称密钥算法加密消息**。
20. (PPT-CH2-73) 一个加密算法的明文和密文一样长，请问：该加密算法是语义安全的吗？**否**。

21. (课后习题) 数据是数字经济时代核心的生产要素。
22. (课后习题) 隐私保护不仅要保护用户数据的机密性，还要保护用户行为数据的不可区分性，也就是对用户元数据的保护。

ai给的答案

23. (补充) 访问控制技术是信息系统安全的核心技术之一，该技术中主体是请求访问的实体，客体是接受访问的实体，访问控制策略/规则是主体对客体的访问规则集。
24. (距离定义) 如果 x' 是通过从 x 删除一行来构造的，则 $d(x, x') = 1$ 。
25. (距离定义) 如果 x' 是通过从 x 修改一行来构造的，则 $d(x, x') = 1$ 。
26. (安全概念) 消息锁定加密是语义安全的吗？否。
27. (安全概念) 收敛加密是语义安全的吗？否。

二、 选择题

1. 下述哪些安全概念等价于语义安全？()

- A. NM-CPA
- B. IND-CCA
- C. PRV\$-CDA
- D. IND-CPA

2. 下述哪些陈述是正确的？()

- A. AES 加密算法是语义安全的
- B. RSA-OAEP 加密算法是语义安全的
- C. AES-CTR 加密方案是语义安全的
- D. 椭圆曲线加密算法是语义安全的

3. 下述哪些陈述是正确的？()

- A. AES-CBC 加密方案是语义安全的
- B. RSA 加密算法是语义安全的
- C. AES-GCM 加密方案是语义安全的
- D. ElGamal 加密算法是语义安全的

4. TLS 握手协议的任务包括：()

- A. 协商密钥规格
- B. 利用公钥证书来认证服务器的身份

- C. 生成会话密钥
- D. 用会话密钥加密传输的数据

5. 以下关于 FIDO 协议的论述哪些是正确的？ ()

- A. FIDO 协议的在线身份认证采用了非对称公钥密码技术来提供安全保障
- B. FIDO 协议包括本地身份识别与在线身份认证两部分
- C. FIDO 协议支持指纹、语音、虹膜、脸部识别等生物身份识别方式
- D. FIDO 协议的在线身份认证采用了对称密码技术来提供安全保障

6. 由于计算机的普及，很多攻击者具有更强大的计算能力。1979年，Robert Morris 和 Ken Thompson 提出了哈希加盐（Hashing and Salting）的方法来对口令进行加密处理，来抵抗字典攻击和暴力破解，并应用于 Unix 操作系统。以下哪些方法比哈希加盐的方法更安全？ ()

- A. PBKDF2 (Password-Based Key Derivation Function)
- B. BCrypt
- C. SCrypt
- D. Argon2

7. 以下哪些技术是用来解决仿冒证书问题的？ ()

- A. CT (Certificate Transparency)
- B. HTTP Public Key Pinning (HPKP)
- C. CDN
- D. 自动证书管理环境 (ACME) 协议

8. 实现数据匿名化的主要方法有： ()

- A. 泛化
- B. 抑制
- C. 聚合
- D. 过滤

9. 容器与虚拟机相比较的优势有： ()

- A. 占用存储空间小，下载传输快
- B. 消耗的 CPU 和内存更少
- C. 启动速度更快
- D. 更安全

10. 容器与虚拟机相比较，下述哪些陈述是正确的？ ()

- A. 容器占用存储空间小，下载传输快
- B. 容器消耗的 CPU 和内存更少
- C. 容器启动速度更快
- D. 容器安全性比虚拟机低

11. Paillier 加密算法是： ()

- A. 对称密码算法
- B. 公钥密码算法
- C. 加法同态加密算法
- D. 乘法同态加密算法

12. 静态数据发布原则 L-diversity 保证发布数据集的披露风险小于： ()

- A. $1/L$
- B. $2/L$
- C. $1/(2L)$
- D. $1/(3L)$

13. 遵循 K 匿名模型发布数据，数据集的披露风险小于： ()

- A. $1/K$
- B. $2/K$
- C. $1/(2K)$
- D. $1/(3K)$

14. 发起者需要在发起匿名通信之前确定整个通信的传输路径的是： ()

- A. 基于 Mix 算法的匿名通信
- B. 基于洋葱路由算法的匿名通信
- C. 基于泛洪算法的匿名通信
- D. Tor 匿名通信

15. 以下 HTTPS 的部署模式中，哪个是最安全的？ ()

- A. HTTP 和 HTTPS 并存
- B. HTTP 默认跳转到 HTTPS
- C. 持久跳转 HTTPS (HSTS)
- D. HSTS + HSTS Preload

三、综合题与简答题

1. 隐私的定义、分类、及其度量与量化表示。(10分)

2. 阐述 SSL 握手协议的主要流程，然后分析一下 SSL 握手协议中 RSA 密钥交换的安全性，并提出改进方案。(10分)

3. 解释一下姚氏混淆电路的工作原理。(10分)

4. 阐述加密数据去重的基本原理。(10分)

5. 简述 K 匿名、L 多样性、T 相近隐私保护模型的基本思想及其存在的问题。(10分)

6. 简答题 (10分)

- (1) 概念解释：K 匿名与记录链接攻击 (4分)
- (2) 概念解释：L 多样化与属性链接攻击 (4分)
- (3) 数据匿名化方法的局限性 (2分)

7. 数据可恢复性证明 POR 机制的基本思路。(10分)

8. 简要解释 POR 机制的基本工作原理。(5分)

9. 安全多方计算问题 (15分)

- (1) 请阐述姚期智提出的百万富翁问题的解决方案，并对其正确性和安全性进行分析。(9分)
- (2) 设计一个基于 OT 协议的百万富翁问题解决方案，并给出一个该 OT 协议的具体实现方案 (如果能够给出课堂上没有讲过的 OT 协议实现方案，本题目可以获得额外加分)。(6分)

10. 同态加密 (10分)

- (1) 请给出同态加密的定义。
- (2) 证明：RSA 算法是乘法同态的。
- (3) 证明：Paillier 算法是加法同态的。

11. 简答题 (8分)

- (1) 什么是不可区分性？ (2分)
- (2) 什么是不可塑性？ (2分)
- (3) 攻击模型 (例如，CPA 和 CCA) 与安全目标 (例如，NM 和 IND) 相结合，可以构建安全概念 NM-CPA，NM-CCA，IND-CPA 和 IND-CCA。请解释一下四个安全概念之间的关系。(4分)

12. 解释一下 OpenID Connect 协议与 OAuth 协议的关系与区别，以授权码模式和隐式模式为例画图说明。(5分)

13. 简答题：TLS 协议的安全性 (5分)

- (1) TLS 协议如何防止传输的消息被窃听和篡改? (2分)
- (2) TLS 协议如何防止中间人攻击? (1分)
- (3) TLS 协议如何防止消息重放攻击? (1分)
- (4) TLS 协议如何提供前向安全性的? (1分)

14. 简答题 (5分)

- (1) 简述 HTTP Strict Transport Security (通常简称为 HSTS) 的概念。
- (2) 解释 HSTS Preload List 的作用与工作原理。
- (3) 描述 HSTS 响应头格式。

15. Paillier 密码算法：对于同一个明文 m ，为什么每次加密出来的密文不同却都能够正确解密出明文 m ? 请予以证明。(3分)

16. 估算用户秘密的熵值 (4分)

- (1) 有一款加密货币钱包，其助记词词典包含 2048 个单词，生成密语种子时用户选择的助记词由助记词词典中的 12 个英文单词组成。分析一下该加密货币钱包助记词的熵值。(2分)
- (2) 某应用系统的口令设置，要求用户口令必须包含数字、大小写字母、特殊字符，口令长度不少于 10 个字符。分析一下该应用系统用户口令的安全性。(2分)

17. 简答题 (5分)

- (1) 如何计算两个数据集之间的距离? 如何定义临近数据集? (2分)
- (2) 如果 x' 是通过向 x 添加一行来构造的， x' 与 x 是相邻的吗? 为什么? (1分)
- (3) 在差分隐私中，对于任意两个临近数据集 x 和 x' 和查询函数 f ，如何计算敏感度? (1分)
- (4) 计数问询的敏感度的是多少? (1分)

四、简述工作原理

1. 阐述差分隐私的工作原理 (10分)。

2. 简述 ACME 协议的作用与工作原理 (5分)。

3. 解释 Kerberos 协议的工作原理 (5分)。

五、有图表的题目与图表分析

注意：本部分题目需要参考原试卷中的图表或图片。

1. (图表题 1)

- (此处原题包含图表)

2. (图表题 2)

- (此处原题包含图表)

3. 题目：数据安全传输：TLS 握手协议的安全性分析 (10分)

- 需参考图a和图b
- (1) 解释一下什么是前向安全性？
- (2) 分析图 a 所示的握手协议是否满足前向安全性？
- (3) 分析图 b 所示的握手协议是否满足前向安全性？
- (4) 解释一下针对 DHE 协议的中间人攻击方法。
- (5) 分析一下：图 b 所示的握手协议是如何抵抗中间人攻击的？

4. 题目：数据匿名化技术：计算 K 匿名和 L 多样性的参数 (10分)

- 表：经过匿名化处理的数据集 (需参考原题表格)
- (1) 该数据集是否满足 K 匿名？如果满足，K 的值是多少？ (3分)
- (2) 该数据集是否满足 L 多样性？如果满足，L 的值是多少？ (3分)
- (3) 该数据集是否满足 T 相近？解释为什么？ (4分)